ACTIVITÉ PRATIQUE — CYBERSÉCURITÉ

Attaque MITM SSH

Man-in-the-Middle sur un service SSH — ARP Spoofing et contre-mesures

Mathis PAOLINI

CaenSup Sainte-Ursule

Partie 1 — Attaque MITM d'un service SSH

Q1. Pourquoi l'accès aux machines virtuelles par la console ou l'interface graphique n'est pas possible avec le super-administrateur root ?

↳ Par défaut, dans le fichier de configuration SSH, l'accès en super-administrateur n'est pas autorisé. Il faut ajouter la ligne PermitRootLogin yes dans le fichier /etc/ssh/sshd_config pour l'activer.

```
PermitRootLogin yes
```

Q2. Expliquer à quoi sert la commande sudo et quels avantages a-t-elle sur l'utilisation de la commande su - ?

↳ La commande sudo permet d'élever les droits uniquement pour une commande précise. La commande su permet de basculer complètement en mode root dans un shell, ce qui est plus dangereux. Utiliser sudo est donc plus sûr car l'élévation de privilèges est limitée à la commande concernée.

Q3. Quelles commandes permettent de savoir si le service OpenSSH (serveur) est déjà installé et démarré ?

↳ La commande systemctl status ssh permet de voir l'état du service OpenSSH.

```
systemctl status ssh
```

```
etusio@srvssh:~$ systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/lib/systemd/system/ssh.service; enabled; vendor preset: enab
   Active: active (running) since Tue 2025-11-25 08:40:55 CET; 47min ago
     Docs: man:sshd(8)
           man:sshd_config(5)
  Process: 425 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
 Main PID: 454 (sshd)
```

Q4. Indiquer le répertoire où sont stockées les clés publique et privée créées ainsi que le positionnement des permissions appliquées sur les fichiers correspondants. Quel est le fichier de configuration du service SSH ?

↳ Les clés publique et privée sont stockées dans /etc/ssh/. La commande ls -l permet de voir les permissions sur les fichiers du répertoire. Le fichier de configuration du service SSH est sshd_config.

```
ls -l /etc/ssh/
```

```
etusio@srvssh:/etc/ssh$ ls -l /etc/ssh/
total 584
-rw-r--r-- 1 root root 565189 janv. 31  2020 moduli
-rw-r--r-- 1 root root   1580 janv. 31  2020 ssh_config
-rw-r--r-- 1 root root   3250 janv. 31  2020 sshd_config
-rw------- 1 root root    505 mars  29  2020 ssh_host_ecdsa_key
-rw-r--r-- 1 root root    173 mars  29  2020 ssh_host_ecdsa_key.pub
-rw------- 1 root root    399 mars  29  2020 ssh_host_ed25519_key
-rw-r--r-- 1 root root     93 mars  29  2020 ssh_host_ed25519_key.pub
-rw------- 1 root root   1823 mars  29  2020 ssh_host_rsa_key
-rw-r--r-- 1 root root    393 mars  29  2020 ssh_host_rsa_key.pub
```

Première utilisation — Annexes 1 à 5

Q5. Que signifie cette alerte qui est affichée à l'écran ? Devez-vous continuer l'opération ? Pourquoi ?

↳ Cette alerte signifie que l'authenticité de l'hôte « srvssh.local.sio.fr » ne peut pas être établie car il n'est pas encore connu. On peut continuer l'opération : le client va l'ajouter dans le fichier known_hosts des hôtes connus.

```
Warning: Permanently added 'srvssh.local.sio.fr' (ECDSA) to the list of known hosts.
```

Q6. Lors d'une prochaine connexion depuis le même client sur ce serveur, ce message apparaîtra-t-il à nouveau ? Pourquoi ?

↳ Non, ce message n'apparaîtra plus car le serveur est désormais connu (présent dans known_hosts). Le client demandera uniquement le mot de passe pour la connexion SSH.

```
etusio@clissh:~$ ssh etusio@srvssh.local.sio.fr
etusio@srvssh.local.sio.fr's password:
```

Q7. Sur la machine virtuelle cliente, expliquer à quoi sert le fichier /home/etusio/.ssh/known_hosts.

↳ Le fichier known_hosts contient la liste des hôtes SSH connus de la machine cliente, avec leur empreinte. Lorsqu'une connexion est établie, le client vérifie que l'empreinte du serveur correspond à celle enregistrée. Si elle diffère, une alerte de sécurité est affichée.

⚠ À ce stade du TP, supprimer le contenu du fichier known_hosts (ne pas supprimer le fichier lui-même).

```
echo > ~/.ssh/known_hosts
```

```
etusio@clissh:~/.ssh$ cat known_hosts
|1|2oN8XpD3DVmrioTHQkNLRQBQmQU=|LgxHnqmsGwlY3CXYCgz/y6GV
bmlzdHAyNTYAAABBBKBIccKG7qS9Tmm7DkTS1/HU2k7qtgloRAg+fb4e
|1|kBZxpC44dHNqgPpEgmpATi7iY2w=|6qoj3dMMi6QaR+W2HYNhAFBk
bmlzdHAyNTYAAABBBKBIccKG7qS9Tmm7DkTS1/HU2k7qtgloRAg+fb4e
etusio@clissh:~/.ssh$
etusio@clissh:~/.ssh$
etusio@clissh:~/.ssh$ echo > ~/.ssh/known_hosts
etusio@clissh:~/.ssh$ cat known_hosts

etusio@clissh:~/.ssh$
```

Découverte des hôtes et services présents sur un réseau local

Q8. Indiquer quelles sont les informations que peut obtenir un attaquant grâce à ces commandes ?

↳ La commande nmap -sP 192.168.56.0/24 permet de lister les machines en ligne sur le réseau. La commande nmap -sV 192.168.56.10 permet de connaître les services en écoute et leurs versions sur la machine cible.

```
nmap -sP 192.168.56.0/24
nmap -sV 192.168.56.10
```

```
etusio@kali:~$ nmap -sP 192.168.56.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-25 09:55 CET
Nmap scan report for 192.168.56.1
Host is up (0.00067s latency).
Nmap scan report for srvssh.local.sio.fr (192.168.56.10)
Host is up (0.00052s latency).
Nmap scan report for clissh.local.sio.fr (192.168.56.11)
Host is up (0.00082s latency).
Nmap scan report for kali.local.sio.fr (192.168.56.12)
Host is up (0.00079s latency).
Nmap scan report for rwbsd.local.sio.fr (192.168.56.254)
Host is up (0.0019s latency).
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.65 seconds
```

```
PORT    STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
53/tcp open  domain  ISC BIND 9.11.5-P4-5.1+deb10u2 (Debian Linux)
```

Partie 2 — Simulation de l'attaque Man-in-the-Middle

Q9. Expliquer les principes généraux d'une attaque de l'homme du milieu (Man in the Middle).

↳ Une attaque MITM a pour but d'intercepter les communications entre deux parties sans qu'elles ne s'en doutent. L'attaquant se positionne entre le client et le serveur, et peut non seulement lire mais aussi modifier les messages échangés. Elle est notamment applicable dans l'échange de clés Diffie-Hellman.

🔴 Dans une attaque MITM, l'attaquant peut lire ET modifier les communications en temps réel, à l'insu des deux parties.

Analyser le cache ARP sur le serveur SSH et le client SSH avant l'attaque :

```
arp -a
```

Sur le serveur SSH :

```
etusio@srvssh:~$ ip neigh show
192.168.56.1 dev enp0s3 lladdr 0a:00:27:00:00:06 REACHABLE
192.168.56.12 dev enp0s3 lladdr 08:00:27:32:9e:4e STALE
192.168.56.11 dev enp0s3 lladdr 08:00:27:38:7e:d0 STALE
192.168.56.254 dev enp0s3 lladdr 08:00:27:b5:90:ee STALE
```

Sur le client SSH :

```
etusio@clissh:~/.ssh$ ip neigh show
192.168.56.12 dev enp0s3 lladdr 08:00:27:32:9e:4e STALE
192.168.56.1 dev enp0s3 lladdr 0a:00:27:00:00:06 REACHABLE
192.168.56.10 dev enp0s3 lladdr 08:00:27:c2:c5:ca STALE
192.168.56.254 dev enp0s3 lladdr 08:00:27:b5:90:ee STALE
```

Q10. Noter les associations adresse IP / adresse MAC présentes sur les deux machines. Sont-elles cohérentes ?

↳ Oui, les associations IP / MAC sont cohérentes avant l'attaque : chaque adresse IP correspond à une adresse MAC unique et légitime.

Q11. Pourquoi l'activation du routage sur la machine de l'attaquant est-elle indispensable au bon fonctionnement de l'attaque MITM ?

↳ L'activation du routage permet à la machine de l'attaquant de retransmettre les paquets entre le client et le serveur. Sans cela, les communications seraient simplement coupées et l'attaque serait détectée. Le routage permet à la Kali Linux de se faire passer pour le routeur tout en laissant transiter le trafic normalement.

```
echo 1 > /proc/sys/net/ipv4/ip_forward
```

Q12. Pourquoi cette redirection de ports est-elle indispensable au succès de l'attaque de l'homme du milieu ?

↳ La redirection de port permet de capter les connexions SSH du client (port 22) sur la machine Kali, puis de les renvoyer vers le port 2222 pour éviter de déclencher le propre service SSH de Kali. Grâce au routage activé, Kali retransmet ensuite les paquets vers le vrai serveur SSH sans que le client s'en rende compte.

```
iptables -t nat -A PREROUTING -p tcp --dport 22 -j REDIRECT --to-port 2222
```

Mise en place de l'ARP Spoofing

Q13. Indiquer en quoi une attaque de type ARP Spoofing peut être utile ici au pirate ?

↳ L'ARP Spoofing permet à l'attaquant d'usurper les adresses MAC du client et du serveur, forçant ainsi toutes les trames Ethernet à transiter par sa machine. Il peut alors intercepter les données sans être remarqué.

Q14. Comparer les caches ARP du client et du serveur avec les associations notées lors de la Q10. Qu'en concluez-vous ?

Sur le serveur SSH (après attaque) :

```
etusio@srvssh:~$ ip neigh show
192.168.56.1 dev enp0s3 lladdr 0a:00:27:00:00:06 DELAY
192.168.56.12 dev enp0s3 lladdr 08:00:27:32:9e:4e STALE
192.168.56.11 dev enp0s3 lladdr 08:00:27:32:9e:4e REACHABLE
192.168.56.254 dev enp0s3 lladdr 08:00:27:b5:90:ee STALE
```

Sur le client SSH (après attaque) :

```
etusio@clissh:~/.ssh$ ip neigh show
192.168.56.12 dev enp0s3 lladdr 08:00:27:32:9e:4e STALE
192.168.56.1 dev enp0s3 lladdr 0a:00:27:00:00:06 DELAY
192.168.56.10 dev enp0s3 lladdr 08:00:27:32:9e:4e REACHABLE
192.168.56.254 dev enp0s3 lladdr 08:00:27:b5:90:ee STALE
```

↳ On peut voir que les adresses MAC des machines 192.168.56.11 et 192.168.56.12 sont désormais identiques (celle de la machine Kali). L'ARP Spoofing a bien été réussi : toutes les trames passent par l'attaquant.

Q15. À partir de ces observations, expliquer en détails comment fonctionne une attaque ARP Spoofing.

↳ L'attaquant envoie de fausses trames ARP en masse pour corrompre les caches ARP du client et du serveur. Comme le protocole ARP ne vérifie pas l'authenticité des trames, les deux victimes enregistrent l'adresse MAC de l'attaquant en lieu et place de l'adresse MAC légitime de leur interlocuteur. Tout le trafic transite alors par la machine de l'attaquant.

Partie 3 — Exploitation de l'attaque MITM

Q16. Envoyer un ping depuis le client vers le serveur (192.168.56.10) et vérifier via une capture sur Kali que les trames passent par l'attaquant. Quels éléments démontrent que l'attaque se déroule correctement ?

```
ping 192.168.56.10
```

Captures Wireshark sur la machine Kali :

```
Ethernet II, Src: PcsCompu_32:9e:4e (08:00:27:32:9e:4e), Dst: PcsCompu_c2:c5:ca (08:00:27:c2:c5:ca)
  Destination: PcsCompu_c2:c5:ca (08:00:27:c2:c5:ca)
  Source: PcsCompu_32:9e:4e (08:00:27:32:9e:4e)
```

```
Ethernet II, Src: PcsCompu_c2:c5:ca (08:00:27:c2:c5:ca), Dst: PcsCompu_32:9e:4e (08:00:27:32:9e:4e)
  Destination: PcsCompu_32:9e:4e (08:00:27:32:9e:4e)
  Source: PcsCompu_c2:c5:ca (08:00:27:c2:c5:ca)
```

↳ Sur les deux captures, la source et la destination de deux paquets différents affichent la même adresse MAC — celle de la machine Kali Linux. Cela prouve que toutes les communications transitent bien par l'attaquant.

Q17. Recopier la ligne qui contient le login et le mot de passe capturés dans le fichier /var/log/auth.log.

```
tail -f /var/log/auth.log
```

```
Dec  1 09:37:52 kali sshd_mitm[2020]: INTERCEPTED PASSWORD: hostname: [192.168.56.10]; username: [etusio]; password: [Fghijkl1234*] [preauth]
```

Q18. Que contient le fichier /home/ssh-mitm/shell_session_0.txt présent sur Kali Linux ?

```
  GNU nano 4.9.1
ime: 2025-12-01 08:37:52 GMT
Server: 192.168.56.10:22
Client: 192.168.56.11:59988
Username: etusio
Password: Fghijkl1234*
=======================
Linux srvssh 4.19.0-8-amd64 #1 SMP Debian 4.19.98-1+deb10u1 (2020-04-27) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Mon Dec  1 09:33:46 2025 from 192.168.56.11
^[]0;etusio@srvssh: ~^Getusio@srvssh:~$ sudo cat /etc/shadowsudo cat /etc/shadow
[sudo] Mot de passe de etusio : Fghijkl1234*
```

↳ Le fichier contient l'intégralité de la session SSH interceptée : toutes les commandes tapées par l'utilisateur légitime sont enregistrées par l'outil ssh-mitm.

Q19. Expliquer pourquoi le message d'erreur SSH apparaît après l'attaque.

↳ Lors de la première connexion via l'attaquant, le client a mémorisé l'adresse MAC de la machine Kali associée au nom d'hôte et à l'adresse IP du serveur SSH. Lors d'une reconnexion directe (sans l'attaquant), l'adresse MAC ne correspond plus à l'entrée du fichier known_hosts, ce qui déclenche l'alerte de sécurité SSH.

🔴 Ce message d'erreur est précisément la contre-mesure que SSH met en place contre les attaques MITM : toute modification de l'empreinte du serveur est signalée.

Partie 4 — Contre-mesures

Q20. Proposer une solution afin de pouvoir à nouveau se connecter au service SSH depuis le client.

↳ Il suffit de vider le contenu du fichier known_hosts pour supprimer l'ancienne empreinte mémorisée. La prochaine connexion demandera de confirmer la nouvelle empreinte.

```
echo > ~/.ssh/known_hosts
```

💡 Contre-mesures recommandées pour se protéger des attaques MITM SSH : utiliser des clés SSH plutôt que des mots de passe, activer la vérification stricte des empreintes, configurer du chiffrement fort, et surveiller les changements inattendus dans known_hosts.

Conclusion

Cette activité a permis de comprendre et de mettre en œuvre une attaque Man-in-the-Middle sur un service SSH, en s'appuyant sur l'ARP Spoofing pour intercepter le trafic réseau. Les outils nmap, arpspoof et ssh-mitm ont permis de visualiser concrètement comment un attaquant peut capturer des identifiants et espionner des sessions SSH.

La contre-mesure principale de SSH — la vérification de l'empreinte du serveur via le fichier known_hosts — s'est révélée efficace pour alerter l'utilisateur en cas de changement suspect. L'utilisation d'une authentification par clés plutôt que par mot de passe renforce significativement la sécurité contre ce type d'attaque.